BREACHSIEVE - Vulnerability Assessment Report

Target: http://localhost:3000 | Date: 2026-10-17 15:52:41 UTC

Risk Score	Critical	High	Medium	Low	False Positives	Novel Patterns
8.3	**0**	**3**	**1**	**0**	**2**	**1**

Scope & Authorization Record

Target URL	http://localhost:3000
Scan Mode	PASSIVE (Active Confirmed: 0)
Authorization Status	CONFIRMED - Explicit authorization granted by operator
Authorized At	2026-10-17T15:51:28.388784+00:00
In-Scope Rules	localhost:3000 127.0.0.1
Out-of-Scope Rules	None

Confirmed Vulnerability Findings (4)

[BS-FIND-001] Missing Anti-clickjacking Header - **Medium (CVSS: 6.9)**

CWE: CWE-1021 | **OWASP:** A05:2021-Security Misconfiguration | **MITRE:** T1190
URL: http://localhost:3000
Description: The response does not protect against 'ClickJacking' attacks. It should include either Content-Security-Policy with 'frame-ancestors' directive or X-Frame-Options.
Gemini AI Verdict: [CONFIRMED] The response status is 'HTTP/1.1 200 OK' and serves HTML content as indicated by 'Content-Type: text/html'. Neither 'X-Frame-Options' nor a 'Content-Security-Policy' header with the 'frame-ancestors' directive is present in the response headers, leaving the application rendered in '<title>frontend</title>' vulnerable to framing and clickjacking attacks.
Remediation: Add 'Content-Security-Policy: frame-ancestors 'self'' (or 'none') and 'X-Frame-Options: SAMEORIGIN' (or 'DENY') headers to all HTML responses.

[BS-FIND-002] X-Content-Type-Options Header Missing - **High (CVSS: 8.0)**

CWE: CWE-693 | **OWASP:** A05:2021-Security Misconfiguration | **MITRE:** T1562
URL: http://localhost:3000/favicon.svg
Description: The Anti-MIME-Sniffing header X-Content-Type-Options was not set to 'nosniff'. This allows older versions of Internet Explorer and Chrome to perform MIME-sniffing on the response body, potentially causing the response body to be interpreted and displayed as a content type other than the declared content type. Current (early 2014) and legacy versions of Firefox will use the declared content type (if one is set), rather than performing MIME-sniffing.
Gemini AI Verdict: [CONFIRMED] The response returns 'HTTP/1.1 200 OK' with 'Content-Type: image/svg+xml', but completely omits the 'X-Content-Type-Options' security header. Because SVG files can carry executable scripts and XML payloads, failing to enforce 'nosniff' leaves the resource susceptible to MIME-type sniffing vulnerabilities in supporting user agents.
Remediation: Configure the web server or application framework to send 'X-Content-Type-Options: nosniff' on all HTTP responses, including static assets.

[BS-FIND-003] Content Security Policy (CSP) Header Not Set - **High (CVSS: 8.0)**

CWE: CWE-693 | **OWASP:** A05:2021-Security Misconfiguration | **MITRE:** T1562
URL: http://localhost:3000
Description: Content Security Policy (CSP) is an added layer of security that helps to detect and mitigate certain types of attacks, including Cross Site Scripting (XSS) and data injection attacks. These attacks are used for everything from data theft to site defacement or distribution of malware. CSP provides a set of standard HTTP headers that allow website owners to declare approved sources of content that browsers should be allowed to load on that page — covered types are JavaScript, CSS, HTML frames, fonts, images and embeddable objects such as Java applets, ActiveX, audio and video files.
Gemini AI Verdict: [CONFIRMED] The response returns an HTML document as indicated by "Content-Type: text/html" and the body starting with "<!doctype html>". However, the response headers completely lack a "Content-Security-Policy" header, and the HTML "<head>" contains no "<meta http-equiv="Content-Security-Policy">" tag. This directly confirms the scanner's finding of a missing CSP.
Remediation: Configure the web server or reverse proxy to serve an appropriate Content-Security-Policy (CSP) HTTP response header defining approved origins for scripts, styles, and other resources.

[BS-FIND-006] HTTP Only Site - **High (CVSS: 8.5)**

CWE: CWE-311 | **OWASP:** A05:2021-Security Misconfiguration | **MITRE:** T1190
URL: http://localhost:3000
Description: The site is only served under HTTP and not HTTPS.
Gemini AI Verdict: [CONFIRMED] Confirmed vulnerability based on corroborating scanner evidence: ".
Remediation: Configure your web or application server to use SSL (https).

Remediation Summary Matrix

ID	Title	Severity	Actionable Fix
BS-FIND-001	Missing Anti-clickjacking Head	Medium	Add 'Content-Security-Policy: frame-ancestors 'self'' (or 'none') and 'X-Frame-Options: S
BS-FIND-002	X-Content-Type-Options Header	High	Configure the web server or application framework to send 'X-Content-Type-Options: no
BS-FIND-003	Content Security Policy (CSP)	High	Configure the web server or reverse proxy to serve an appropriate Content-Security-Pol
BS-FIND-006	HTTP Only Site	High	Configure your web or application server to use SSL (https)....

Methodology Note

This assessment was performed using automated OWASP ZAP scanning driven through its REST API, restricted to strictly verified in-scope allow-list rules. Alerts were triaged via Google Gemini API using evidence-based analysis to filter false positives and identify novel patterns. This automated assessment augments, not replaces, comprehensive manual security testing.